

A starter Acceptable Use Policy for AI tools

Six clauses that close the highest-risk gaps in 30 minutes.

Your highest near-term AI risk is not a model failure. It is a teller pasting a customer's date of birth into a public chat tool to ask it to summarize an email. A short, written policy closes that gap faster than any technical control.

Six clauses. Adapt the language to your institution. Run the final version past your compliance officer and legal counsel before adoption.

The six clauses

- 1. No customer PII or NPI in public AI tools.** No names, account numbers, dates of birth, addresses, SSNs, balances, or transaction details may be entered into any AI tool that is not on the bank's approved list. Synthetic or redacted examples are permitted.
- 2. No internal financial figures in public AI tools.** Pre-release earnings, board materials, examination findings, and confidential strategy may not be entered into any AI tool that is not on the bank's approved list.
- 3. Human review of every output.** No AI-generated content may be sent to a customer, a regulator, a vendor, or a board member without review and approval by a named bank employee.
- 4. Approved tools list.** [List the tools your bank has approved. Start with one or two — do not list everything you can think of.] All other AI tools require IT and compliance review before use.
- 5. Reporting.** If a banker realizes they have entered restricted information into an unapproved tool, they must report it to [named person] within 24 hours. Reports made in good faith do not result in disciplinary action.
- 6. Annual acknowledgement.** Every staff member who uses any AI tool — paid or free — signs this policy at hire and annually thereafter.

Three things you can do this week

- 1. Adopt the policy or a redlined version of it within 30 days.** Perfect is the enemy of written.
- 2. Hold one 15-minute town hall** to walk through the six clauses. Read them out loud. Ask for questions.
- 3. Add the policy as a slide in next month's all-staff training.**

A starter prompt to redline the policy

I am drafting an AI Acceptable Use Policy for our community bank. Below is a starter version. Help me identify clauses that may be too strict or too loose for an institution our size, and suggest language tightenings. Do not introduce new clauses unless you can tie them to a specific federal banking regulation. [Paste the policy here.]

Citations

- AIEOG AI Lexicon, US Treasury / FBIIC / FSSCC, February 2026 — third-party AI risk, AI governance
- Interagency Guidance on Third-Party Relationships: Risk Management, FDIC / OCC / Fed, 2023
- SR 26-2 Revised Guidance on Model Risk Management, FRB / OCC / FDIC (supersedes SR 11-7)
- ECOA / Regulation B, Consumer Financial Protection Bureau